

IAS 2 — INFORMATION ASSURANCE AND SECURITY 2 (ITAS311-T)

COMPLETE EXAM REVIEWER — LESSONS L3 to L8

Course & Reference Details: - **Course Code:** ITAS311-T (Information Assurance and Security 2) - **Instructor:** Prof. Pops Madiaga - **Schedule:** Monday | 8:00 AM – 11:45 AM - **Class:** 3rd Year 1st Sem · BSIT-S-3A · UniverseFactory - **Source Material:** [ias2-reviewer-reference.pdf](#) (Strict 100% Slide-Grounded Reviewer)

TABLE OF CONTENTS

1. [L3: Post Audit Activities](#)
 2. [L4: Log Information and Security Controls](#)
 3. [L5: Post Audit Activities \(Deep Dive & Practical Application\)](#)
 4. [L6: Risk Management Process](#)
 5. [L7: Business Continuity Management \(BCM\)](#)
 6. [L8: Backing Up Data and Application & Incident Handling](#)
-

L3: POST AUDIT ACTIVITIES

A. Introduction: What are Post-Audit Activities?

- **Definition:** Post-audit activities are the activities performed after the audit has been conducted to **review, analyze, document, and communicate** the results of the audit.
- **Core Purpose:** They help the organization understand the audit findings, address identified issues, and determine appropriate actions for improvement.

B. The Exit Interview

- **Definition:** An exit interview, also called an **exit or closing meeting**, is a meeting held at the conclusion of audit fieldwork, when necessary, to discuss audit findings, resolve questions or concerns, and address outstanding issues before the final audit report is released.
- **Three Core Objectives:** 1. **Clarify** — Resolve questions or concerns about the audit results. 2. **Discuss** — Address other issues or outstanding matters before finalization. 3. **Prepare** — Allow the audit client to provide responses and comments before the final report is issued.
- **Where It Fits in the Audit Lifecycle:** $\text{Audit Fieldwork} \rightarrow \text{Exit Interview} \rightarrow \text{Management Responses \& Comments} \rightarrow \text{Draft Report Review} \rightarrow \text{Final Audit Report}$

B1. Participants in the Exit Interview

1. **Audit Team:** - Conducts and facilitates the audit. - Presents and explains the audit results. - *Example:* Lead Auditor / Audit Team Leader. - *Purpose:* Present and explain the audit findings, facilitate the discussion, and address questions or concerns about the audit.
2. **Management of the Audited Entity:** - *Example:* Dean, Chairperson, Director, or managers responsible for the audited functions. - *Purpose:* Review the findings, provide explanations or additional context, and respond to issues identified during the audit.
3. **Other Participants:** - Other individuals invited by the audit client. - *Purpose:* Provide relevant information, clarification, or perspective regarding the audited processes or findings.

B2. Purpose of the Exit Interview

- Gives the auditor and the audited entity an opportunity to discuss findings, clarify concerns, and establish a common understanding before the report is finalized.
- **Clarify Findings:** Discuss audit findings and resolve misunderstandings about the audit process, evidence, or conclusions.
- **Obtain Management Response:** Allow management to provide explanations, additional context, and responses to identified issues.
- **Discuss Improvements:** Discuss recommendations, corrective actions, responsibilities, and timelines.
- **Identify Risks & Weaknesses:** Provide an objective view of weaknesses and areas requiring attention.

B3. How Auditors Use the Exit Interview

- Auditors use the meeting to identify and discuss **missing or outstanding information** that may still be needed before the audit is completed.
- **Two Key Questions Asked by Auditors:** 1. **WHO?** — Who is responsible for providing the missing information? 2. **WHEN?** — When can the auditor expect the information to be provided?
- *Slide Example:* The IT department has not submitted its latest access-control review or user-permission logs. During the exit interview, the auditor identifies this gap, asks who is responsible, and establishes a deadline for submission before the report is finalized.

B4. What to Prepare Before the Auditors Leave

Establishing target dates helps the organization schedule tasks according to the audit timeline and keeps everyone accountable:

1. **Set a Target Date for the Draft Audit Report** — Establish when the draft audit report is expected to be completed.
2. **Determine the Approval Timeline** — Estimate how long the organization's internal review and approval process will take.
3. **Set a Target Date for the Final Report** — Agree on when the final audit report is expected to be issued.

B5. Advantages and Limitations of the Exit Interview

- **Advantages:**
- **Resolves Issues Early:** Allows questions, misunderstandings, and missing information to be addressed before the report is finalized.
- **Keeps Everyone Accountable:** Establishes responsibilities and target dates for outstanding items and reporting.
- **Improves Accuracy:** Allows the audited entity to provide additional context and correct possible misunderstandings or errors.
- **Prevents Surprises:** Ensures that findings and next steps are discussed before the final report is issued.
- **Limitations:**
- **Not Required in Every Audit:** The exit interview is held when necessary rather than being mandatory for every audit.
- **Time Constraints:** Limited time may be available to present findings, answer questions, and discuss outstanding issues.
- **Issues May Remain Unresolved:** Disagreements between the auditor and audited entity may still remain. If differences of opinion remain, they may simply be documented and included in the audit report.
- **Communication Gaps:** Technical audit findings may be difficult for some non-technical participants to understand.

C. Data Analysis in Auditing

- **Definition:** The intelligence generated from reviewing audit-related information, often using technology. Like other types of data analytics, audit analytics typically involve analyzing large sets of numbers to find actionable audit insights.

The Five Steps to Get You Started With Data Analysis

1. **Step 1: Define Questions and Goals** - Ask a targeted hypothesis before searching data for answers (avoid open-ended questions). - *Targeted Questions:* "How have certain metrics changed over time?" and "Do these metrics correlate with others, and if so, how strongly?" - Helps determine the type of analysis needed and what data is most relevant.
2. **Step 2: Collect Data** - Data can include sales records, customer demographics, lead tracking, net promoter scores, etc. - When using BI tools, ensure data is accessible and proper connections are set between your data warehouse and your BI tool. - Volume depends on questions; not having enough data can skew analysis results.
3. **Step 3: Data Wrangling** - Cleansing data before analysis to make sure it is in a usable format. - Entails searching for **outliers**, dealing with **null values**, and looking for data that may have been **incorrectly input**.
- Step 4: Determine Analysis** - Choosing the analytical method based on defined questions and goals:
 - **Diagnostic Analysis:** Uses data to search for the cause of, and a solution to, an existing problem.
 - **Descriptive Analysis:** A way to describe the data by summarizing key sections.
 - **Predictive Analysis:** Combines historical data and statistical modeling to forecast how certain metrics will perform in the future.

Step 5: Interpret Results - Determine what is learned from the results. Combining multiple visualizations in one report enables users to tell a story about their data that leaders can use to take actions, make changes, or refocus efforts. Can prompt deeper questions and restart the analysis cycle.

D. Generation of Audit Reports

- **Definition & Objective:** The auditor gathers evidence and observes, tests, compares, and confirms until gaining reasonable assurance and forms an opinion of whether the financial statements/records are free of fraud or error. The auditor then presents an audit opinion.
- **Purpose of an Audit Report:** 1. Formal Communication 2. Documentation of Evidence 3. Initiation of Corrective Action Closure
- **Benefits of an Audit Report:** 1. Actionable Roadmap 2. Strategic Oversight 3. Historical Benchmarking 4. Accountability

Standard Audit Report Format (11 Parts)

1. **Title:** Must explicitly mention '**Independent Auditor's Report**'.
2. **Addressee:** Mentions to whom the report is being presented (e.g., Board of Directors, Audit Committee).
3. **Introductory Paragraph:** Statement that the financial statements or systems described in the report have been audited.
4. **Management's Responsibility:** Mentions management's responsibility for the integrity of financial statements, internal controls, financial performance, and maintaining accounting records to prevent fraud.

5. **Auditor's Responsibility:** Mentions the duty to plan and execute the audit to procure reasonable assurance, depict an unbiased opinion, comply with ethical requirements, and follow Standards on Auditing.
6. **Opinion: The most critical content in an Audit Report.** Mentions the impression derived after auditing.
7. **Basis of the Opinion:** Mentions the facts of the premise and the standards that support the opinion.
8. **Other Reporting Responsibility:** Mentions supplementary reporting duties, such as regulatory requirements.
9. **Signature of the Auditor:** Confirms the authenticity of the audit report.
10. **Place of Signature:** The name of the city in which the signing of the report happened.
11. **Date of Audit Report:** The date on which the audit report is signed/reported.

E. Presentation of Findings

- **Definition:** The stage where the audit team formally communicates and discusses the results of the audit — findings, conclusions, and recommendations — with relevant stakeholders once the report is finalized or nearing finalization.
- **Purpose:** Gives the audit team and stakeholders a shared moment to understand results, decide on action, and move forward with clear accountability: 1. **Communicate Results** — Ensure stakeholders clearly understand what the audit uncovered. 2. **Ensure Accountability** — Assign ownership of recommendations and agree on timelines. 3. **Support Decision-Making** — Give management the information needed to prioritize and act. 4. **Promote Transparency** — Build trust by openly discussing both strengths and weaknesses.

How Findings Are Presented (5 Steps)

1. **Step 1: Prepare a Clear Summary** — Organize findings by priority or risk level, not by discovery order.
2. **Step 2: Use Visual Aids** — Charts and risk matrices help non-technical stakeholders follow quickly.
3. **Step 3: State Finding, Impact, Fix** — For each issue: what was found, why it matters, what to do.
4. **Step 4: Open the Floor** — Let management respond and clarify before conclusions are locked in.
5. **Step 5: Document Agreed Actions** — Record decisions, owners, and deadlines during the meeting.

What to Prepare Before the Presentation

- **Finalize the Report Draft:** Ensure findings, evidence, and recommendations are accurate and complete.
- **Anticipate Questions:** Prepare supporting evidence for findings likely to be challenged.
- **Prioritize Findings:** Rank issues by severity or risk so critical items are discussed first.
- **Set an Agenda:** Allocate time per topic so discussion doesn't run over or skip items.

Advantages and Limitations of Presenting Findings

- **Advantages:**
 - **Ensures Understanding:** Reduces the chance findings are misread before action is taken.
 - **Drives Accountability:** Assigns clear ownership and deadlines for fixes.
 - **Builds Buy-In:** Stakeholders act faster on findings they helped discuss.
 - **Surfaces Context:** Management may explain factors the audit team missed.
- **Limitations:**
 - **Time-Constrained:** Complex findings may need to be condensed, losing nuance.
 - **Stakeholder Resistance:** Management may dispute or downplay findings.
 - **Technical Gaps:** Non-technical audiences may struggle with audit language.
 - **Delayed Follow-Through:** Agreement in the room doesn't guarantee timely action.

L4: LOG INFORMATION AND SECURITY CONTROLS

A. Introduction to Security Logging

- **Definition:** Security logs record activities occurring on computers, networks, applications, and security devices.
 - **Why Organizations Use Logs:** 1. Detect unauthorized access. 2. Investigate security incidents. 3. Verify security controls. 4. Support audits and compliance.
 - **4 Important Log Questions Answered:**
 - **WHO** performed the action?
 - **WHAT** happened?
 - **WHEN** did it happen?
 - **WHERE** did it originate?
-

B. Types of Log Information to Capture

1. **Authentication Logs:** Successful and failed logins, password changes, multi-factor authentication events, account lockouts.
 2. **Authorization Logs:** Access to restricted files, privilege changes, administrative actions.
 3. **Network Logs:** Firewall connections, blocked traffic, VPN activity, network scans.
 4. **System and Application Logs:** Operating-system errors, software installations, configuration changes, application failures, user transactions. - **NIST IDPS Log Fields:** National Institute of Standards and Technology (NIST) identifies the **timestamp**, **event type**, **event source**, and **sensor or reporting system** as important information for IDPS events.
-

C. Intrusion Detection System (IDS)

- **Definition:** An IDS monitors activity and detects possible attacks or policy violations. An IDS generally **generates alerts rather than blocking activity automatically**.
 - **What IDS Can Monitor:** Network traffic, system activity, user behavior, application events, authentication attempts.
 - **Two Main Types:**
 - **NIDS (Network-based IDS):** Monitors network traffic.
 - **HIDS (Host-based IDS):** Monitors individual computers or servers.
 - **IDS Log Information Captured:** Alert ID number, date and time of detection, source and destination IP addresses, ports and network protocol, detection rule or signature, suspected attack type, severity level, affected host/account/app, IDS sensor generating alert, response/action taken.
 - **4 IDS Detection Methods:** 1. **Signature-based:** Detects known attack patterns. 2. **Anomaly-based:** Identifies activity that differs from normal behavior. 3. **Protocol analysis:** Detects improper use of network protocols. 4. **Event correlation:** Combines multiple events to identify a larger attack.
-

D. Verifying Security Controls

Security controls should be tested to confirm they work as intended in an authorized, controlled environment:

- Review system and IDS configurations.
 - Confirm logging is enabled on important devices.
 - Perform an authorized failed-login or test intrusion.
 - Verify that the activity creates a log entry.
 - Confirm that the IDS generates the correct alert.
 - Check whether alerts reach the security team or SIEM.
 - Validate timestamps and required log fields.
 - Review false positives and missed events.
 - Document test results and corrective actions.
-

E. Protecting Logs

Log management includes: **generating, transmitting, storing, accessing, and disposing** of log data.

- Store logs in a centralized log-management platform or SIEM.
- Restrict log access to authorized personnel.
- Encrypt logs during transmission and storage.
- Separate log storage from the systems generating the logs.
- Monitor attempts to modify or delete logs.
- Use hashes, digital signatures, or append-only storage to protect integrity.
- Establish retention and disposal policies.
- Monitor whether log sources stop sending data.
- Protect logs because they contain sensitive user, system, and security information.

Log Review and Incident Response

- Logs should be reviewed continuously or according to a documented schedule.
- **Security Teams Should Investigate:** Repeated failed logins, privilege escalation, disabled security services, malware detection, unexpected administrator activity, large or unusual data transfers.
- IDS alerts should be correlated with firewall, authentication, endpoint, and application logs.
- **6 Steps When Suspicious Activity is Identified:** 1. Validate the alert. 2. Identify affected systems. 3. Preserve relevant evidence. 4. Contain the activity. 5. Investigate and document the incident. 6. Improve security controls based on the findings.

F. Intrusion Detection Analysis Methods

Core methodologies that Intrusion Detection Systems (IDS) and security analysts use to inspect network traffic, system events, and log files to discover unauthorized or malicious activities.

The 3 Core Detection Methods

1. **Signature-Based Analysis (Misuse Detection):** - Scans network packets and system logs for specific patterns, byte sequences, or malicious instruction code—known as "signatures"—that match recorded threats. - *Pros:* Highly accurate for known threats; generates very few false positives. - *Cons:* Entirely blind to new, zero-day vulnerabilities and morphing malware.
2. **Anomaly-Based Analysis:** - Relies on machine learning or statistical modeling to build a rigid baseline profile of standard system or network operations. Logs any deviation from this baseline as a potential attack. - *Pros:* Capable of detecting brand-new, novel, or zero-day threats. - *Cons:* High rate of false positives caused by legitimate, unusual user spikes or system changes.
3. **Stateful Protocol Analysis (Specification-Based Analysis):** - Compares network activity against universal vendor profiles of how protocols should structurally behave. Tracks the state of network pairings over time (differs from anomaly detection which learns normal behavior from history). - *Pros:* Easily catches protocol manipulation, illegal commands, and scanning attempts. - *Cons:* Consumes heavy system resource overhead to continuously track state conditions across layers.

Supplementary Profiling Techniques

- **Threshold Monitoring:** Alerts defenders when pre-set operational limits are broken (e.g., failed login attempts).
- **Resource Profiling:** Tracks system-wide consumption metrics like CPU, RAM, and bandwidth to find sneaky background malware.
- **Executable Profiling:** Continuously analyzes how active software programs invoke system calls and read system memory.

G. Host Based Intrusion Detection System (HIDS)

- **Definition:** Cybersecurity tool that monitors an individual device or host for suspicious activity, unauthorized file changes, and malicious behavior.
- **How Does It Work?** 1. **Data Collection:** Gathers raw data directly from the host (system logs, app event logs, auth records, kernel activities). 2. **File Integrity Monitoring (FIM):** Tracks critical system files, configuration settings, and executables by comparing current states against baseline snapshots to catch unauthorized changes. 3. **Analysis and Matching:** Evaluates collected data using Signature-based and Anomaly-based techniques. 4. **Alerting and Logging:** Logs event details and immediately sends an alert to security administrators.

H. Layered Defense (Defense in Depth)

- **Definition:** A security strategy that uses multiple security controls at different levels of an information system. Instead of depending on a single security mechanism, organizations create several defensive layers. If one layer fails or is bypassed, another layer can still detect, prevent, or limit the attack.
- **The 7 Security Layers:**

Security Layer	What It Protects	Examples of Security Controls
1. Physical Security	Physical access to equipment	Locks, guards, access cards, cameras
2. Network Security	Network connections and traffic	Firewalls, segmentation, NAC
3. Detection	Identifies suspicious activity	IDS/IPS, traffic analysis
4. Endpoint/Host Security	Individual computers and servers	Antivirus/EDR, HIDS, host firewall
5. Application Security	Applications and their functions	Authentication, authorization, input validation
6. Data Security	Information itself	Encryption, backups, access controls
7. Monitoring & Logging	Visibility and investigation	Logs, SIEM, alerts, audit trails

I. Network Access Control (NAC)

- **Definition:** A security approach that controls which users and devices are allowed to connect to and use network resources.
- **What NAC Can Evaluate:**
- **User Identity:** Username, authentication credentials, user role.
- **Device Identity:** Device type, MAC address, device certificate, device ownership.
- **Security Posture:** Operating system, security updates, endpoint protection status, security configuration.
- **Network Requirements:** Which network the device should access, which resources the user should be allowed to reach.
- **4 Possible NAC Decisions:** 1. **Allow** — Granted access to authorized network segments. 2. **Deny** — Connection rejected completely. 3. **Restrict** — Limited network access. 4. **Quarantine** — Isolated to a remediation network to update/fix security posture.

Network Access Control Process (5 Steps): $\text{Identification} \rightarrow \text{Authentication} \rightarrow \text{Security Assessment} \rightarrow \text{Authorization} \rightarrow \text{Monitoring}$

Verifying Network Access Control (5 Scenarios):

- **Authorized User:** Authorized employee accesses required resources for their role.
- **Unauthorized User:** Unauthorized account is denied access to protected resources.
- **Unknown Device:** Unrecognized/unapproved device is tested to ensure restriction/denial.
- **Non-Compliant Device:** Device intentionally missing requirements (e.g. patches) is tested.
- **Disabled Account:** Authentication is attempted using a disabled account to verify rejection.

J. Host Isolation

- **Definition & Primary Purpose:** A security technique that separates a computer, server, or endpoint from other systems when the host is suspected of being compromised or presenting a security risk. The primary purpose is **containment**. Instead of immediately shutting down the computer, security administrators isolate its network communication so investigators can still examine the system.
- **Why Host Isolation is Necessary (7 Risks of a Compromised Computer):** 1. Spread malware. 2. Attack other computers. 3. Steal credentials. 4. Communicate with an attacker's server. 5. Access sensitive resources. 6. Transfer stolen information. 7. Serve as a starting point for further attacks.
- **Possible Indicators Prompting Host Isolation:**
- Malware Detection (malware or ransomware detected).
- Suspicious Processes (unknown or malicious process running).
- Abnormal Network Connections (communicating with suspicious external systems).

- Credential Compromise (stolen user credentials).
- Data Exfiltration (unusual amount of data transferred outside).
- Unauthorized System Changes (critical system files or configurations modified).
- IDS/HIDS Alerts (suspicious activity originating from host).
- **5 Main Objectives of Host Isolation:** 1. **Containment:** Prevent the threat from spreading. 2. **Protection:** Protect other systems and sensitive information. 3. **Investigation:** Allow security personnel to examine the affected host. 4. **Evidence Preservation:** Avoid unnecessary changes that could destroy useful investigation evidence. 5. **Recovery:** Provide time to remove the threat and restore the system safely.
- **6 Verifying Host Isolation Steps:** 1. **Identify the Host:** Confirm affected device and reason for isolation. 2. **Apply Isolation:** Use NAC, endpoint security, firewall rules, or network segmentation. 3. **Test Connectivity:** Check whether the host can still access restricted systems. 4. **Review Logs:** Examine firewall, NAC, IDS, and endpoint logs for connection attempts. 5. **Compare Results:** Make sure actual behavior matches the isolation policy. 6. **Document Findings:** Record tests, results, and any problems discovered.

K. System Hardening

- **Definition:** The process of securing a computer system by reducing or eliminating vulnerabilities that could be exploited by attackers. It involves configuring the operating system, applications, network services, and user accounts according to security best practices.
- **Why Hardening is Important:** Without hardening, systems may contain unnecessary services, outdated software, weak passwords, or excessive user privileges. These weaknesses provide attackers with opportunities to gain unauthorized access.
- *Slide Example:* A company server running an outdated service contains a known vulnerability. An attacker could exploit that vulnerability to access the server. Applying security updates and disabling unnecessary services reduces this risk.
- **5 Hardening Goals:** 1. Reduce the number of possible attack surfaces. 2. Prevent unauthorized access to systems and data. 3. Protect systems from malware and other cyber threats. 4. Ensure security configurations are properly implemented. 5. Minimize unnecessary services, applications, and permissions.

L. Security Monitoring and Testing

- **Definition:** Continuously observing systems and regularly testing security controls to determine whether they are functioning correctly and protecting against threats.
 - *Monitoring:* Involves collecting and examining information about system and network activity.
 - *Testing:* Evaluates whether security controls can actually protect a system and detect potential threats.
 - **Why Regularly Tested?** New vulnerabilities and threats can appear over time.
 - **4 Common Security Testing Methods:** 1. **Vulnerability Scanning:** Searches systems for known security weaknesses, outdated software, and insecure configurations. 2. **Penetration Testing:** Simulates controlled attacks against a system to determine whether vulnerabilities can actually be exploited. 3. **Security Audits:** Reviews security policies, configurations, and procedures to verify compliance with security requirements. 4. **Log and Alert Testing:** Generates controlled security events to check whether monitoring tools properly record and report them.
-

L5: POST AUDIT ACTIVITIES (DEEP DIVE)

A. Exit Interview (Deep Dive)

- **Definition:** The final formal meeting conducted between the security audit team and key organizational stakeholders/management before the official audit report is published.
- **Core Concept:** Acts as an initial, verbal debriefing session designed to discuss the execution of the audit, initial observations, and preliminary findings in a controlled environment.
- **Context in Auditing:** Represents the transition point from active field testing and evidence collection to formal reporting and remediation planning.
- **Purpose:** Prevent "No Surprises", Fact Verification & Validation, Provide Operational Context, Align Expectations.
- **Format:** Structured, high-level briefing held either in-person or via secure, recorded video conference; typically lasts **30 to 60 minutes**, maintaining a professional, objective, collaborative tone. Supported by an Executive Summary slide deck or position paper.
- **5 Key Parts of the Meeting:** 1. **Executive Opening & Scope Review:** Brief recap of agreed-upon audit boundaries, systems evaluated, and timeline. 2. **Positive Observations:** Recognition of effective security controls, robust practices, and well-maintained systems. 3. **Preliminary Risk & Finding Highlights:** Overview of key vulnerabilities discovered, categorized by high-level threat levels (Critical, High, Medium). 4. **Interactive Discussion / Management Feedback:** Dedicated time for the client team to ask questions, present additional context, or challenge findings. 5. **Next Steps & Deliverable Timeline:** Clear roadmap detailing data analysis completion, final report delivery, and formal response deadlines.
- **Presentation Strategy:**
 - *Focus on Business Impact:* Translate complex technical exploits into tangible business risks.
 - *Adopt a Collaborative Tone:* Frame findings as opportunities for strengthening defense-in-depth rather than placing blame.
 - *Balanced Delivery:* Open with effective controls before transitioning into vulnerabilities to reduce defensiveness.
 - *Be Direct and Precise:* Present high-priority issues clearly without diluting severity.
- **4 Qualities of a Good Exit Interview:**
 - **Objective & Evidence-Based:** Grounded in verifiable logs, screenshots, or configuration files—never assumptions or personal opinions.
 - **Transparent:** Clear about what was tested, testing limitations, and scope areas that could not be evaluated.
 - **Constructive:** Focuses on actionable risk mitigation and improvement strategies rather than punitive fault-finding.
 - **Interactive:** Encourages open dialogue, allowing system owners to provide context without fear of immediate dismissal.

B. Data Analysis (Deep Dive)

- **Definition:** The systematic process of inspecting, cleaning, transforming, and evaluating raw data and security evidence collected during an audit.
- **Core Concept:** Converts raw technical logs, system outputs, and scanner findings into structured, actionable security intelligence.
- **Context in Auditing:** Serves as the critical analytical bridge between raw evidence gathering and the generation of the final audit report.
- **Purpose:** Identify Root Causes, Risk Prioritization (Likelihood vs. Impact), Verify Compliance (e.g., ISO 27001, NIST, PCI-DSS), Eliminate False Positives.
- **Tools Used:** SIEM software, log parsers, script-based data filters, risk matrix models.
- **5 Key Parts:** 1. **Data Normalization & Cleaning:** Aggregating data from multiple sources, standardizing formats, and stripping out false positives. 2. **Correlation & Pattern Analysis:** Cross-referencing firewall logs, server event logs, and intrusion detection alerts to trace malicious activity paths. 3. **Severity Assessment & Scoring:** Applying standardized scoring frameworks (e.g., CVSS) to evaluate vulnerability severity objectively. 4. **Root Cause Breakdown:** Mapping identified vulnerabilities to systemic weaknesses (e.g., lack of patch management, weak access controls). 5. **Trend & Historical Comparison:** Benchmarking current findings against previous audit cycles to measure security posture growth over time.
- **Presentation Strategy:** Leverage Visual Data Representations (heat maps, pie charts, timeline graphs), Structure around Narrative Attack Paths, Distinguish Confirmed vs. Potential Risks, Focus on Actionable Metrics.
- **4 Qualities of Good Data Analysis:** Accurate & Defensible, Context-Aware, Reproducible, Outcome-Oriented.

C. Audit Report (Deep Dive)

- **Definition:** Compiling evidence, analysis, observations, and findings gathered throughout the audit into a formal written document. Summarizes security and control conditions, and communicates overall conclusion or opinion.
- **Finding Components (5 Core Elements):** 1. **Condition:** What was found or observed. 2. **Criteria:** What should have been in place. 3. **Cause:** Why the issue occurred. 4. **Effect / Risk:** Possible impact. 5. **Recommendation:** Action needed to address the issue.
- **6 Qualities of a Good Audit Report:**
 - **Accurate:** Supported by evidence.
 - **Objective:** Free from personal bias.
 - **Clear:** Easy to understand.
 - **Constructive:** Provides practical solutions.
 - **Timely:** Issued promptly.
 - **Confidential:** Sensitive information is protected.
- **Audit Workflow Progression:** $\text{Audit Evidence} \rightarrow \text{Analysis} \rightarrow \text{Findings} \rightarrow \text{Opinion / Conclusion} \rightarrow \text{Audit Report}$

D. Presentation of Findings (Deep Dive)

- **Concept:** Pivotal final communication phase delivering, explaining, and contextualizing verified audit results to management, process owners, and governance committees. Transforms complex audit evidence into actionable business insights.
- **Strategic Role:** Connects technical analysis with executive decision-making and remediation.
- **Deliverables:** Summarizes control gaps, operational risks, policy non-compliances; prioritizes via severity ratings (High, Medium, Low); outlines Corrective Action Plans (CAP) with deadlines and accountability.
- **Advantages and Disadvantages:**
 - **Advantages:** Immediate Clarity & Direct Dialogue, Faster Stakeholder Buy-in, Shared Accountability, Strategic Value Addition.
 - **Disadvantages:** Defensiveness & Conflict, Misinterpretation Risk, Time & Resource Intensive, Scope Creep during Discussion.

3 Real-World Audit Examples (From Slide Reference)

1. **IT & Cybersecurity Audit:** - **Finding:** "58% of employee workstations are missing critical security patches, and default administrator credentials were found active on network switches." - **Impact Presentation:** Visualizes the risk of ransomware infiltration and presents a mandatory 14-day automated patch deployment plan.
2. **Financial Compliance & Inventory Audit:** - **Finding:** "A 12% discrepancy exists between the ERP physical inventory logs and the warehouse cycle counts due to delayed manual data entry." - **Impact Presentation:** Displays loss trends via bar charts and proposes a barcode-scanning workflow to prevent reconciliation errors.
3. **Quality & Safety (ISO/HACCP) Audit:** - **Finding:** "Storage temperatures in Cold Room B exceeded the 4°C limit three times during the quarter without documented corrective actions." - **Impact Presentation:** Highlights regulatory non-compliance risks and presents an automated IoT temperature-alerting framework.

L6: RISK MANAGEMENT PROCESS

A. Risk Identification

- **Definition:** The process of **finding, recognizing, and documenting** potential risks that may affect a project.
- **Role:** **STARTING POINT** of the risk management process.
- **Core Guiding Question:** "*WHAT COULD GO WRONG WHILE DEVELOPING OUR SYSTEM?*"
- **Why Risk Identification is Important (5 Reasons):** 1. Recognize potential problems early. 2. Prepare appropriate responses. 3. Reduce the possibility of response issues. 4. Protect the project's schedule, budget, and objectives. 5. Help the team prioritize which risks need attention.

6 Common Risk Identification Tools and Techniques

1. **Brainstorming:** Team members identify risks such as lack of resources, technical errors, or delays.
2. **Checklists:** A list of common risks from previous projects or established standards is used to identify possible risks. *Example:* A software project checklist may include security problems, data loss, software bugs, and system downtime.
3. **SWOT Analysis:** Examines Strengths (S), Weaknesses (W), Opportunities (O), and Threats (T).
4. **Expert Interviews:** People with specialized knowledge or experience are asked about possible risks. *Example:* A cybersecurity expert may identify security vulnerabilities that the project team might overlook.
5. **Documentation Review:** Existing project documents, contracts, schedules, requirements, and reports are reviewed to find potential risks.
6. **Historical Information:** The team examines risks from previous or similar projects to determine which risks might occur again.

Main Output: Risk Register

- **Definition:** A document that records the risks identified throughout the project.
- **Process of Identification:** $\text{Identify} \rightarrow \text{Document} \rightarrow \text{Record in Risk Register} \rightarrow \text{Proceed to Risk Assessment}$

B. Risk Assessment

- **Definition:** The process of identifying, analyzing, and evaluating risks to determine their significance. Helps organizations decide which risks need treatment and in what order.
- **Core Output:** A prioritized understanding of risk exposure.
- **Foundation for:** Risk response planning (accept, mitigate, transfer, avoid).

Two Approaches to Risk Assessment

Characteristic	Qualitative Risk Assessment	Quantitative Risk Assessment
Basis & Rating	Uses descriptive, judgment-based ratings like Low/Medium/High.	Uses numerical, data-driven values such as dollar amounts and probabilities.
Speed & Effort	Fast and easy to communicate; quick results.	Takes longer to complete; demands detailed historical data.
Tools & Math	Relies on expert judgment/discussion; minimal mathematical calculations.	Requires statistical analysis tools; produces specific numerical outcomes.
Data Requirement	Works well with limited historical data.	Requires detailed historical data.
Slide Example	A startup gives a new vendor a quick "Medium" rating in a team discussion.	A bank calculates a \$2.3M expected annual loss before approving a large loan.

Likelihood and Impact Analysis

- **Likelihood:** Probability that a risk event will occur.
- **Impact:** Severity of consequences if the risk event occurs.

- Both are usually rated on a scale (e.g., 1–5 or Low/Med/High).

Fundamental Formula: $\text{Risk Level} = \text{Likelihood} \times \text{Impact}$

Severity Ranking:

- Rank risks from highest to lowest overall severity score.
- **High-severity risks** $\rightarrow$ Immediate mitigation/action.
- **Low-severity risks** $\rightarrow$ Monitor or accept.
- Ensures resources are allocated efficiently to the most critical threats.

The Risk Matrix

- **Definition:** A visual grid plotting **Likelihood (Y-axis)** vs. **Impact (X-axis)**.
- Cells represent overall risk severity (color-coded: green / yellow / red).
- Helps quickly visualize and communicate risk exposure.
- Simplifies decision-making on where to focus resources.

C. Implementing & Monitoring Risk Responses

4 Steps of Risk Management

1. **Identify Risk**
2. **Assess Risk**
3. **Implement the Risk Response Plan**
4. **Monitor and Control Risk Response**

Implementing the Risk Response Plan

- **Definition:** The process of executing the chosen risk response strategies and actions that were planned during the risk assessment stage.
- **Involves:** Resource Allocation, Assigning Responsibilities, Setting Timelines, Selecting the Right Tools.

4 Risk Response Strategies

1. **Avoid:** Eliminate the risk entirely.
2. **Mitigate:** Reduce the likelihood or impact.
3. **Transfer:** Shift the risk to a third party.
4. **Accept:** Acknowledge and monitor without action.

The Implementation Process (6 Steps)

1. Finalize the chosen response strategy.
2. Assign roles and responsibilities.
3. Allocate budget and resources.
4. Set a timeline / schedule.
5. Execute the planned actions.
6. Document the implementation.

Successful Implementation Requires

- **Clear Ownership:** Who is accountable.
- **Adequate Resources:** Budget, tools, manpower.
- **Open Communication:** Stakeholders informed at every stage.

Monitor and Control Risk Response

- **Definition:** The ongoing process of tracking identified risks, reviewing the effectiveness of response plans, and identifying new risks as they emerge.
- **Involves:** Tracking, Reviewing, Adjusting, Reporting.

- **Monitoring Techniques and Tools:**
 - Regular risk audits and inspections.
 - Key Risk Indicators (KRIs) and dashboards.
 - Status reports and team check-ins.
 - Feedback loops from stakeholders.
-

L7: BUSINESS CONTINUITY MANAGEMENT

A. Foundational Definitions

- **Business Continuity Management (BCM):** An organization-wide framework of policies, processes, and capabilities that prepare a business to prevent, respond to, and recover from disruptive incidents.
- **Business Continuity Plan (BCP):** The documented set of procedures an organization follows to keep critical functions running **during**, and **immediately after**, a disruption.
- **Disaster Recovery (DR):** A technical, IT-focused subset of continuity planning concerned with restoring **systems, data**, and **infrastructure** after an outage.

Key Recovery Metrics

- **Recovery Time Objective (RTO):** The maximum acceptable time to restore a business function after a disruption occurs.
- **Recovery Point Objective (RPO):** The maximum acceptable amount of data loss, measured as a point in time to which data must be restored.
- **Maximum Tolerable Downtime (MTD):** The absolute limit of disruption a function can withstand before survival of the business is threatened.
- **Work Recovery Time (WRT):** The time needed after systems are restored to verify data and resume normal processing.

More Essential Terms

- **Incident, Crisis, and Disaster:** Escalating levels of severity:
 - *Incident:* A minor disruption.
 - *Crisis:* Threatens objectives and reputation.
 - *Disaster:* Causes major, often prolonged, damage.
- **Resilience & Single Point of Failure (SPOF):**
 - *Resilience:* The ability to absorb and adapt to disruption without losing function.
 - *Single Point of Failure (SPOF):* Any single component whose failure stops the entire process.
- **Continuity of Operations:** The sustained delivery of an organization's critical services and functions throughout a disruption, not merely their eventual restoration.

B. Maximum Tolerable Downtime (MTD)

- **Also Called:** Maximum Tolerable Period of Disruption (**MTPD**).
- **Definition:** The longest period a critical business function can be unavailable before the consequences become unacceptable, and potentially threaten the survival of the organization itself.
- **Nature:** It is **not a target to aim for** — it is the outer boundary every recovery strategy must stay inside.
- **Why It Matters:**
 - Anchors every other recovery metric (RTO, RPO, WRT).
 - Differs by function — payroll tolerates more downtime than trading.
 - Drives investment priorities and recovery strategy design.
- **What Drives MTD?** 1. **Financial Impact:** Lost revenue, contractual penalties, and cash-flow strain that accumulate the longer a function stays down. 2. **Reputational Damage:** Erosion of customer, investor, and media trust — damage that often outlasts the outage itself. 3. **Regulatory & Legal Obligations:** Compliance deadlines and statutory duties that create hard limits on acceptable disruption. 4. **Operational Dependencies:** Downstream processes and contractual SLAs with partners that fail once this function is unavailable too long.
- **Cost Escalation Over Time:** Impact rarely rises in a straight line — it **accelerates**. Early hours may be absorbed by buffers and goodwill; each additional day compounds financial, legal, and reputational cost until it approaches the MTD ceiling. MTD marks the point beyond which the curve becomes unacceptable by definition.
- **How RTO, RPO & WRT Fit Within MTD:**
 - RPO looks backward from the disruption to set how much data loss is tolerable.
 - RTO measures the recovery effort itself.
 - WRT covers verification before normal work resumes.

- **Together, RPO + RTO + WRT must fit comfortably inside the MTD boundary.**
- **5 Steps to Determine Acceptable Downtime:** 1. Identify Critical Processes (list functions the organization cannot operate without). 2. Consult Stakeholders & Regulators (gather input from process owners, customers, compliance bodies). 3. Quantify Impact Over Time (model how financial, legal, and reputational harm grows hour by hour). 4. Set the MTD Threshold (agree the point beyond which impact becomes unacceptable). 5. Derive RTO & RPO Targets (work backward to set recovery objectives safely inside that ceiling).

C. Business Impact Analysis (BIA)

- **Definition:** A process to identify and evaluate the effects of a disruption to critical business operations. Key foundation of Business Continuity and Disaster Recovery Planning.
- **Core Question Answered:** *"What happens to the business — financially, operationally, legally, and reputationally — if this process stops working?"*
- **Different from Risk Assessment:**
 - *Risk Assessment asks: "What could go wrong?"*
 - *BIA asks: "What's the impact, and how quickly must we recover?"*
- **Why BIA Matters:**
 - Identifies mission-critical functions vs. deferrable ones.
 - Quantifies financial, operational, legal, and reputational impact.
 - Justifies budget for recovery investments.
 - Prevents over- or under-investing in the wrong priorities.
 - May be required for regulatory compliance.
 - Builds resilience — helps reduce recovery time and unnecessary costs.
 - Aligns business, IT, and leadership on priorities.
- **Key Objectives:**
 - Identify critical business processes and their dependencies (people, systems, data, vendors).
 - Determine how impact escalates over time.
 - Establish clear recovery priorities.
 - Identify resource requirements for recovery (staffing, technology, facilities, vendor support).
 - Surface hidden interdependencies and single points of failure (SPOFs) across departments.
 - Provide a shared understanding across the organization of what "critical" actually means.
- **Core Metrics:** RTO, MTD, RPO, and **MBCO (Minimum Business Continuity Objective)** — the minimum service level the business must maintain during a disruption.

The BIA Process (7 Steps)

1. **Define scope** — Which departments, processes, and locations are covered.
2. **Identify critical business functions** — Through interviews, surveys, and workshops with process owners.
3. **Map dependencies** — People, technology, facilities, data, and third-party vendors.
4. **Assess impact at 7 increasing time intervals** — Across financial, operational, legal, and reputational categories.
5. **Assign RTO, RPO, and MTD** — For each critical process.
6. **Prioritize functions for recovery** — Based on severity and time sensitivity.
7. **Document findings and validate** — With stakeholders; feed results into BCP/DRP.

Types of Impact Assessed (6 Categories)

- **Financial:** Lost revenue, increased costs, penalties.
- **Operational:** Halted production, service failures, lost productivity.
- **Legal/Regulatory:** Compliance breaches, fines, legal obligations.
- **Reputational:** Loss of trust, negative media, brand damage.
- **Contractual:** SLA breaches, penalties, contract termination.
- **Strategic:** Delayed launches, missed opportunities, competitive disadvantage.

Common Tools & Techniques

- **Structured interviews & workshops:** Gather detailed information from department heads and process owners.
- **BIA questionnaires/surveys:** Collect consistent information across different business units.
- **Dependency mapping:** Visualize how processes, systems, people, and vendors depend on each other.
- **Impact-over-time analysis:** Show how the impact of a disruption increases over time.
- **Criticality ranking matrices:** Compare processes and determine which should be prioritized.
- **BCM software:** Standardize and manage BIA activities, especially in larger organizations.

D. Plan Review

• Why Review the Plan?

A continuity plan is **only accurate the day it is written**. Without regular review, it drifts out of step with reality:

- **PEOPLE CHANGE:** Roles, contacts, and responsibilities move on.
- **SYSTEMS CHANGE:** New platforms replace what the plan describes.
- **RISK CHANGE:** New threats emerge that earlier plans never considered.

When to Trigger a Review: 1. **SCHEDULED INTERVAL:** A baseline review, typically annual, regardless of whether anything else has changed. 2. **ORGANIZATIONAL OR TECHNOLOGY CHANGE:** Restructures, mergers, new systems, or office moves that alter dependencies. 3. **AFTER AN INCIDENT OR AUDIT FINDING:** Real events and independent findings are the most reliable evidence a plan needs updating.

• **The Review Process (5 Steps):** 1. **Confirm Scope & Ownership:** Check that named owners and covered functions are still valid. 2. **Validate Contacts & Dependencies:** Update contact lists, suppliers, and system dependencies. 3. **Cross-Check Against the BIA:** Ensure recovery priorities still match current business impact. 4. **Update Procedures:** Revise steps to reflect current people, systems, and processes. 5. **Sign-Off & Version Control:** Formally approve and record the plan as the current controlled version.

- **Roles and Responsibilities:**
- **Senior Management:** Owns the plan overall and formally approves it after review.
- **BC Manager:** Coordinates the review, schedules input, and tracks completion.
- **Department Heads:** Validate that local procedures still reflect how their teams actually work.
- **Internal Audit:** Provides independent assurance that the review was thorough and objective.

E. Testing the Plan

- **Why Test?**
- **Validates Assumptions:** Confirms that the plan's assumptions about people, systems, and timing actually hold up.
- **Uncovers Gaps:** Surfaces missing steps, outdated contacts, and unrealistic timelines before a real event does.
- **Trains Staff:** Builds familiarity and confidence so people know exactly what to do under pressure.
- **Satisfies Compliance:** Demonstrates due diligence to regulators, auditors, and insurers.

The Testing Cycle: $\text{Plan (Document)} \rightarrow \text{Test (Exercise)} \rightarrow \text{Review (Capture results)} \rightarrow \text{Update (Fold lessons into plan)}$

Testing Methods Range: From **tabletop exercises** to **full interruption testing**, proving the plan before a real event occurs.

• Key Takeaways:

- Shared terminology (RTO, RPO, MTD, WRT) keeps every team speaking the same language.
- Maximum Tolerable Downtime is the ceiling every recovery target must fit beneath.
- A Business Impact Analysis turns disruption into numbers, and numbers into priorities.
- Plans decay — scheduled and trigger-based reviews keep them accurate.
- Testing, from tabletop to full interruption, proves the plan before a real event does.

L8: BACKING UP DATA AND APPLICATION

A. Types of Backups

- **Definition:** Backing up data means creating copies of files and systems so they can be restored if the originals are lost, damaged, or corrupted.
- **Tradeoffs:** Speed, storage space, and recovery time.

Backup Type	Description & Tradeoffs	Speed to Create	Speed to Restore	Storage Space Used
1. Full Backup	Copies all data. Slowest to create, fastest to restore, uses the most storage.	Slowest	Fastest	Most Storage
2. Incremental Backup	Copies data changed since the last backup of any kind (full or incremental). Faster and storage-efficient, but restore takes longer because multiple backup sets are needed.	Fastest	Slowest	Least Storage
3. Differential Backup	Copies all data changed since the last full backup . Grows larger over time than incremental, but faster to restore because only two backup sets are needed: full + latest differential.	Moderate	Moderate / Faster than Incremental	Moderate
4. Mirror Backup	Creates an exact, real-time copy of source data, continuously updated. Does not keep older versions of files (no version history) . If a file is deleted from source, it is removed from mirror (no rollback protection).	Real-time	Fastest Access	High Storage / No Versioning

B. Preparation (Incident Handling Phase 1)

- **Overview:** Preparation is the first phase of Incident Handling. Goal: Get the organization ready before an incident happens. Reduces damage and response time. Involves people, processes, and technology readiness.
- **Policies & Plans:**
 - Establish an Incident Response Policy.
 - Develop an Incident Response Plan (IRP).
 - Define roles and responsibilities (Incident Response Team).
 - Set up communication and escalation procedures.
- **Tools & Resources:**
 - Deploy security tools (IDS/IPS, firewalls, antivirus, logging systems).
 - Maintain updated hardware/software inventory.
 - Prepare forensic tools and **"jump kit"** (forensic drives, cables, checklists).

- Ensure backup systems are in place and tested.
- **Training & Testing:**
- Ongoing cycle: regular employee awareness training, tabletop drills/simulations, testing communication channels, periodic plan review.

C. Identification (Incident Handling Phase 2)

- **Overview:** Separates true security incidents from false alarms, determining scope, nature, and severity. Early, accurate identification limits damage.
- **Detection Sources:** Alerts from IDS/IPS, antivirus, SIEM tools; log analysis; employee reports; system/network performance anomalies.
- **Verification Steps:**
 - Confirm the event is a real security incident.
 - Gather initial evidence (timestamps, affected systems, indicators).
 - Classify incident type and severity level.
 - Document findings as they're discovered (**chain of custody**).
- **Next Actions:** Notify Incident Response Team, assign handler/owner, preserve evidence, move to Containment once confirmed.

D. The Three-Phase Response Model

Once an incident is detected, three coordinated phases determine how well an organization survives: $\text{Notification} \rightarrow \text{Response} \rightarrow \text{Recovery}$

D1. Notification

- **Alert the right people, at the right time, through the right channels.** Notification lists must be prepared before an incident occurs.
- **Who Should Be Informed (5 Groups):** 1. **Internal IT & Security Teams:** Incident response team, sysadmins, network/security staff who investigate and act. 2. **Management & Executives:** Leadership needing situational awareness and approving major decisions. 3. **Legal & Compliance Officers:** Assess regulatory obligations, liability exposure, and mandatory disclosure. 4. **Affected Users & Customers:** Anyone whose data, accounts, or services were impacted, so they can protect themselves. 5. **Law Enforcement & Regulators:** Required for certain incidents (breaches, fraud) under law or regulation.
- **Reporting the Incident (4 Principles):**
 - *Standardized Reports:* Detail what happened, when, affected systems, initial impact.
 - *Defined Communication:* Follow pre-defined chains to reach people first time.
 - *Audit Trail Logging:* Log every single step with precise timestamps and actions.
 - *Factual Accuracy:* Strictly factual and updated; avoid speculation.
- **Why Timely Notification Matters (4 Reasons):** 1. Limits the Damage (early isolation stops spread). 2. Meets Legal Deadlines (strict windows, e.g., 72 hours). 3. Preserves Vital Trust (prompt, honest disclosure). 4. Speeds Up Recovery (faster stakeholder engagement).

D2. Response (Containment & Eradication)

- **Containing the Incident:** Stops spread while preserving evidence:
 - *Isolate affected systems:* Disconnect devices or network segments to stop lateral movement.
 - *Disable compromised accounts:* Suspend or reset credentials.
 - *Apply short-term fixes:* Block malicious IPs, close exploited ports, apply emergency firewall rules.
 - *Preserve evidence:* Capture logs, memory dumps, and system states before making changes.
- **Preventing Further Damage (4 Steps):** 1. Continuous Monitoring (signs of spreading or recurring). 2. Patch Vulnerabilities (patch related flaws elsewhere). 3. Segment Networks (limit future blast radius). 4. Staff Communication (interim safety measures).
- **Removing the Cause (Eradication - 4 Steps):** 1. Root Cause Identification (malware, misconfiguration, credentials, unpatched flaw). 2. Malware Eradication (eradicate malicious code, backdoors, unauthorized accounts). 3. Close Vulnerabilities (close specific vulnerability that allowed the incident). 4. Eradication Verification (verify eradication with scans and audits before declaring clean).

D3. Recovery

- **Restoring Systems & Data From Backups:** Brings business back online using clean, verified backups — never data that may still be compromised.
- *Identify a Clean Restore Point:* Backup taken before incident occurred, confirmed free of malware.
- *Rebuild on Trusted Media:* Reinstall systems from verified, uninfected sources.
- *Restore in Priority Order:* Bring back critical business systems first.
- **Testing if Systems Work Properly (4 Steps):** 1. Verify Functionality (confirm applications, services, data accurate and complete). 2. Security Scans (confirm no trace of original threat remains). 3. Performance Check (check performance under normal load). 4. Obtain Sign-Off (get sign-off from IT, security, and business owners before going live).
- **Returning to Normal Operations (4 Steps):** 1. Gradual Rollout (bring systems online gradually, monitor closely). 2. Notify Stakeholders (inform users services are restored and safe). 3. Resume Monitoring (resume normal monitoring routines). 4. Lessons Learned (document lessons learned and update IR plan).

E. Post Incident Review (PIR)

- **4 Key Questions:** 1. *What happened, and when?* 2. *Were the documented procedures followed, and were they adequate?* 3. *What slowed the recovery down?* 4. *What do we do differently next time?*
- **Find the Real Cause, Not Just the Symptom:**
 - *Symptom:* "The server went down."
 - *Real Cause:* Nobody was watching the disk space, and nobody had ever tested a restore.
 - *Method:* Keep asking "why?" until reaching something you can actually fix $\rightarrow$ **The 5 Whys.**
- **Check If the Backup Really Worked (Two Questions):** 1. *How much data did we lose, and could we afford to lose that much?* (This is the **RPO**). 2. *How long were we down, and was that fast enough?* (This is the **RTO**).
 - A backup that turns out damaged or three weeks old is itself a finding.
- **Every finding needs a person in charge and a due date.** Then update response plan, backup policy, and guides.
- **Numbers to Track:**
 - **MTTD:** How long it took to notice the problem (Mean Time to Detect).
 - **MTTR:** How long it took to fix it (Mean Time to Remediate / Resolve).
 - Total downtime, data lost, and cost.

F. Documentation

- **Starts the moment you detect the incident — you do NOT write it at the end.**
- **The Running Log:** Responders write down each step, with the time, while they are still working on the problem.
- **What to Write Down (8 Key Items):** 1. **Incident ID:** One number that connects all records together. 2. **Discovery:** When it was found, how it was found, and who found it. 3. **Scope:** Which systems, applications, and data were affected. 4. **Severity:** How serious it was rated, and who rated it. 5. **Actions:** Every step taken, in order, with the exact time. 6. **Notifications:** Who was told, when, and through what channel. 7. **Evidence:** Copies of logs, file checksums, and record of who handled them. 8. **Backup Used:** Which backup was restored, its date, and whether it was tested.
- **Golden Rule: Write facts only. Never write guesses.**
- **Legal Status:** The log is **evidence**. It can be used in court, in an insurance claim, or in a government audit. Keep access restricted, and keep the log for as long as policy requires.

G. Reporting

- **One Incident, Five Different Readers:** 1. **Technical Team:** Full timeline, signs of attack, real cause, and fixes still to be done. 2. **Management:** Short summary of 1 to 2 pages (cost, downtime, business impact, resources needed to prevent recurrence). 3. **Legal Team and Government Regulator:** Official breach notice filed before the legal deadline. 4. **Affected Users:** Plain language (what happened, what personal data was exposed, what they should do now). 5. **Law Enforcement:** Only when a crime was committed (fraud, extortion, theft of data).
- **What Goes Inside the Written Report (10 Parts):** 1. **Executive Summary:** Written last, read first. 2. **Incident Overview:** What it was, and how serious. 3. **Timeline:** From detection to closing, with times. 4. **Systems and Data Affected:** What was hit, and how much. 5. **Root Cause:** The real reason, not the symptom. 6. **Response and Recovery:** What the team did, including which backup was used. 7. **Impact Assessment:** The section managers read twice (justifies budget for fixes; money lost, downtime, data lost,

reputation damage). 8. **Lessons Learned:** What worked, and what did not. 9. **Recommendations:** Each one with a person in charge and a due date. 10. **Appendices:** Logs, screenshots, and other evidence.

Required by Law (Republic Act 10173 & NPC Circular 16-03)

- **Republic Act 10173 (Data Privacy Act of 2012) & NPC Circular 16-03:**
- **72 Hours:** Notify the National Privacy Commission (NPC) and the people whose data was exposed. The clock starts when you know, or have good reason to believe, that a breach happened. **It does not start when your investigation is finished.**
- **5 Days:** Submit the full breach report, counted from the day you discovered the breach. Asking the NPC for an exemption does not stop the clock.
- **Notice Requirements:** Must state what happened, what personal data was involved, what was done to reduce harm, and who to contact (such as the Data Protection Officer).
- **Enforcement Example: H&M Philippines** was ordered by the NPC to explain why it missed the 72-hour deadline after a payment card incident in 2018.

H. Summary: Key Takeaways

- **Follow-up turns an outage into an improvement:** Find the real cause, not the symptom. Give every fix a person in charge and a due date. Confirm the backup met the RPO and RTO.
- **Documentation is written during the incident, not after it:** It is a running log of facts, with times. It counts as evidence, so keep it factual and keep access restricted.
- **Reporting changes with the reader:** Five audiences, five levels of detail. When personal data is involved, the deadline is **72 hours by law**.